

Red Team Report – FL Client – Ethical Consulting and Technical Analysis (April–May 2025)

This report details the Red Teaming activities carried out for the client FL, an e-commerce operator on the Etsy platform. The intervention focused on an in-depth analysis of the client's home network and digital habits to identify technical and human vulnerabilities. The consultancy, conducted in a real environment between April and May 2025, provides detailed recommendations for improving the security posture through ethical penetration techniques, attack simulations and training.

- Objectives and Scope of Activity

The main purpose of the Red Team activity was to identify and analyze possible vulnerabilities in the customer's home network and in their digital behaviors. The tests were performed in an authorized and controlled context, ensuring operational security throughout the process.

- Passive and active analysis on the home network for mapping and reconnaissance
- Authorized penetration attempts on the primary target machine, a Windows 10 system
- Simulation of ethical phishing attack to assess social risk
- Education and training on anonymity practices, VPN usage, virtualized environments and cyber defense

This combination of technical and behavioral assessments allowed us to identify the most critical areas to mitigate for overall security.

Technical Setup and Instrumentation

The technical phase employed a Kali Linux 2023.4 platform in bridge mode via VirtualBox, to mimic a realistic attack environment. The target network was analyzed with a focus on the entire 192.168.1.0/24 subnet, conducted with advanced scanning and analysis tools.

Tools used: nmap, arp-scan, netdiscover, Wireshark, and Thunderbird for social engineering testing

- MAC vendor identification via arp-scan to map connected devices

- Virtualized operating environment powered by Kali Linux for realistic simulations

- Target subnet observed and analyzed to identify potentially vulnerable devices and resources

These technical assumptions created the basis for a comprehensive reconnaissance and an effective attack simulation.

Network Enumeration and Reconnaissance

Through ARP scans, four active hosts were identified within the target network:

- Address .1: ZTE TIM Gateway Router
- Address .3: Unrecognized device named "Arkadian"
- Address .13: Target PC with Windows 10 system
- Address .11: Red Team Operator's Kali Machine

All devices except Kali were silent to ICMP scans and traditional TCP scans, suggesting the presence of a host-based firewall running in silent drop mode, presumably Windows Defender. This configuration significantly limits the attack surface over the open network.

The recognition thus confirmed a network environment with solid basic defensive measures, requiring more sophisticated approaches and social engineering for compromise.

Nmap Scans and Technical Results

The scans were orchestrated to maximize information collection while maintaining a low-noise, undetectable profile:

- SYN stealth scans (-sS) with -Pn option to skip ICMP
- Firewall scans (-sF, -sN, -sX) to probe firewall rules
- Fragmented packets (-f) to evade some detection systems
- TCP connect scans for all ports (-p-)

- UDP scans on the 50 most common ports (-sU --top-ports 50)
- Aggressive scan (-A) for OS fingerprinting and service detection

No open ports were detected on the target machine, confirming a local firewall effectively configured to block all incoming connections. These results indicate a basic but solid technical security posture, limiting attacks to unconventional or social vectors.

Ethical Phishing Attack Simulation

As a behavioral test, a simulated email message was crafted and sent containing a link disguised as "[Click here](#)". This link led to an image with an ethical message aimed at making people reflect on the risk of real attacks.

The customer clicked the link, demonstrating, with the action, the vulnerability to the social engineering technique. This result highlights how the human factor represents, to date, the largest attack surface and remains a critical point to be mitigated with training and technological tools.

This test was a crucial component of the report, outlining a critical area for future defense strategy.

Education, Recommendations and Suggested Improvements

At the conclusion of the activity, detailed recommendations were provided to improve the overall safety of the client. Recommendations include:

- Use of personal VPNs to encrypt traffic and protect browsing even on

- Implementation of virtualized environments (VirtualBox) for experimental or work operations separated from the main system
- Using password managers to securely manage credentials
- Use of filtered DNS to block malicious domains
- Home network segmentation to isolate IoT devices and reduce risk of compromise
- Training on recognizing and dealing with potentially dangerous emails, including disabling automatic HTML viewing in email clients such as Thunderbird

These measures are essential to elevate multi-layered defense and effectively reduce the risk of compromise through technical and behavioral vectors.

Conclusions and Overall Evaluation

The activity of Red Team highlighted a well-configured technical system for basic security, with an effective host-based firewall and no open ports visible to the outside. However, the main risk arises from the human factor, demonstrated by the ease of "catching" the customer with a phishing simulation.

The client has demonstrated excellent availability and interest in adopting the proposed practices and suggestions, an essential element for medium-long term strengthening.

It is recommended to implement education, segmentation and use of VPNs and virtualized environments as a priority to reduce both the technical and human attack surface.